



Data security that starts with identity™

SharePoint Best Practices for Governance, Security and Setup Success

About Netwrix and This Guide

Netwrix is a leader in identity-first data security. We help organizations reduce risk by unifying visibility and control across their most critical assets — identities, data, and infrastructure. Our platform simplifies security operations and accelerates time to value, so you can stay ahead of threats and keep pace with change.

This guide provides comprehensive best practices for managing and securing both on-premises SharePoint Server and SharePoint Online environments. It covers governance, access management, data protection, automation, document handling, auditing, and disaster recovery strategies. You'll also learn how to optimize SharePoint architecture, enforce Zero Trust, prevent data leakage, and maintain compliance. Netwrix solutions enhance these efforts by offering deep auditing, effective permissions visibility, and proactive alerting on risks like broken inheritance, external sharing, and excessive access rights.

Introduction

Microsoft SharePoint provides organizations with information management, collaboration, workflow and data integration capabilities they need to drive their business forward. But to get the most value from your investment, you need to know not just how to use SharePoint effectively but also how to ensure it is properly set up, configured and secured. This document details on-prem SharePoint best practices and SharePoint Online best practices for:

- Governance
- Information architecture
- Access management
- Automation
- Auditing
- Backup and recovery

It also offers guidance for setting up an on-prem SharePoint Server environment.

SharePoint Governance

At a high level, SharePoint governance best practices include the following:

- **Implement strong access management.** Establish controls to ensure that only proper users have access to SharePoint content.
- **Develop and communicate policies.** Create and communicate clear guidelines and policies via training for how SharePoint should be used and content should be managed and shared.
- **Implement a change management process.** Describe how to manage changes and updates to SharePoint, including how changes will be communicated, tested and implemented.
- **Align governance with business goals.** Ensure that SharePoint governance aligns with the overall objectives of the organization and supports business operations.
- **Establish a clear governance structure.** Define roles and responsibilities for managing SharePoint, including who has the authority to make decisions, manage content and enforce policies.
- **Monitor and enforce compliance.** Monitor SharePoint usage and content to ensure compliance with governance policies and enforce consequences for non-compliance.
- **Revise documentation regularly.** Keep documentation of governance processes and regularly review and update them to ensure they remain relevant and effective.

SharePoint Information Architecture

SharePoint Server and SharePoint Online share the same core components but have different information architecture approaches.

Information Architecture Components

The following are the key components in SharePoint information architecture:

- **Site** — SharePoint sites provide a central location for storing and sharing documents, tasks, calendars and other resources.
- **List** — SharePoint lists provide a flexible way to organize and manage information within a SharePoint site. For example, they can be used to track tasks, manage contacts, and store data in a structured format. They offer customizable views, sorting and filtering. SharePoint Online offers a more responsive and intuitive option: the modern list. Features include responsive design for different devices, integration with Microsoft 365 services (such as Microsoft Teams, Power Automate and Power Apps), conditional formatting and customizable views.
- **Library** — A SharePoint library provides a central location for document management, version control, metadata, check-in/check-out, and other access control within a SharePoint site.

- **Site collection** — A SharePoint site collection is a group of SharePoint sites that share common settings, features and permissions. They provide a way to organize content and control access for different groups of users, such as departments, projects and teams. Each site collection has its own unique URL.

SharePoint Server Information Architecture

A standard on-prem SharePoint information architecture is hierarchical, with the following three levels:

- **Web application** — Web applications are the top-level containers in SharePoint Server. They can be created only by SharePoint administrators who have both Farm Administrator privileges and Local Administrator permissions on the SharePoint Server.
- **Site collection** — Every web application must have a root site collection, which is the site collection with the same URL as the web application.
- **Sites and subsites** — A site collection is comprised of one root site and all subsites below it. All content is stored in these sites and subsites; web applications and site collections are simply containers that do not store any content directly.

SharePoint Online Information Architecture

In contrast to the hierarchy of SharePoint Server, SharePoint Online use flat architecture: Every site is a site collection. When you no longer need a site, you can archive or delete it with little impact. The following types of sites are available:

- **Team sites and communication sites** — Team sites provide a central location for members of specific projects, departments or other groups to share files and collaborate. Communication sites are designed for communicating information, so they provide features like news feeds, events calendars and document libraries. Both types of sites are highly customizable and integrate with other Microsoft 365 tools such as Teams, Outlook and OneDrive.
- **Hub sites** — A hub site organizes a set of related team and communication sites, such as those associated with a particular project, department or region. Hub sites offer cross-site navigation, content roll-up, theming and branding capabilities.

Best Practices for SharePoint Online Information Architecture

When designing your SharePoint Online implementation, follow these best practices:

- Carefully define the SharePoint Online site structure. Keep in mind the following constraints:
 - A site can have up to 2,000 subsites. In general, it's better to create sites and organize them into hubs instead of creating a large number of subsites.
 - Your organization is limited to 2,000 hub sites. You might not need a hub site for every function.
- Plan the content and navigation of the site to ensure that users can easily find what they are looking for. Use clear

and concise headings and organize content into logical sections.

- Use templates to create consistent site layouts and designs. SharePoint Online provides several templates to choose from, including team sites, communication sites, and hub sites.
- Customize the site to meet the needs of your team or organization. Add custom web parts, themes, and branding to enhance the user experience.
- Organize content logically and use clear, concise headings so users can easily find what they are looking for.
- Take advantage of features like custom web parts, themes and branding, team calendars, and discussion boards.

Access Management

1. Configure authentication properly

1.1 For SharePoint Server, use Kerberos or SAML as your authentication standard

Kerberos is a modern authentication protocol that is used in every Active Directory implementation. It is far more secure than the older NTLM because instead of passing password hashes to and from services, Kerberos uses tickets.

Security Assertion Markup Language (SAML) is a modern authentication standard that presents claims about a user to a service. Based on the identity claim contained in the SAML assertion, the service will authorize the user to the service. SAML is a favorite with modern services due to its ability to federate with disparate services that do not have a dependency on the authentication service the user authenticates with.

Authentication options include:

- **Windows authentication**, which enables users to log in using their Windows credentials
- **Forms-based authentication**, which allows users to log in using custom forms and credentials stored in a membership database, making it suitable for scenarios where Windows authentication is not feasible.

More broadly, SharePoint supports multifactor authentication (MFA), which adds an extra layer of security by requiring users to provide additional verification, such as a one-time code sent to their mobile device, in addition to their password.

2. Control SharePoint permissions

Here are the SharePoint permission levels and the actions they enable:

- **Full Control** — Complete control over the site, including the ability to manage permissions, create and delete sites, and modify site settings.
- **Design** — Create and edit lists, document libraries, and pages, as well as customize the look and feel of the site

- **Edit** — Add, edit and delete items on the site, such as documents, lists and web part
- **Contribute** — Add and edit items on the site but not delete them
- **Read (or View Only)** — View items on the site but not make any changes
- **Limited Access** — This permission level is automatically assigned to users who do not have permission to a site but need access to a specific item. For example, a guess account might need to view a document or list item.
- **Approve** — Approve or reject items that require approval before they can be published on the site.

When a root site is created, the user who creates it will specify its administrators, who can then grant other users appropriate permissions to the site. Follow these best practices when granting permissions:

- **Avoid granting additional permissions at the web application level.** Default policy grants certain accounts permissions at this level; for instance, the Search Crawl account has Full Read permissions on every web application it needs to crawl. While you can grant additional permissions at this level, it's recommended to use only the default policies if possible.
- **Use role-based access control (RBAC).** To help ensure accuracy and reduce provisioning effort, grant permissions to SharePoint resources to roles, and then assign those roles to the appropriate individuals or groups. There are three default SharePoint roles:
 - **Site owner** — Members of this group can manage permissions, add or delete content, and customize the site.
 - **Member** — Users in this group can add, edit and delete content on the site.
 - **Visitor** — Members of this group can view content but cannot make any changes.

Administrators can create additional roles that meet their organization's needs.

- **Use Active Directory groups.** You can configure SharePoint to use an alternate source for users and groups to make security assignment easier and clearer.
- **Consider using [information barriers](#) for SharePoint Online.** Information barriers are Microsoft 365 policies that admins can configure to prevent users from communicating and collaborating with each other. This functionality is most commonly used in organizations that need to adhere to strict governance policies and compliance requirements.

3. Prevent Data Loss

3.1 Use SharePoint Information Rights Management (IRM)

IRM helps organizations protect SharePoint data by applying protection to documents and list items that travel with the content. That is, administrators can define policies that restrict access to specific documents or list items even after they have been downloaded from SharePoint. IRM further protects content with features such as document expiration and dynamic watermarking.

3.2 Use SharePoint Data Loss Prevention (DLP)

SharePoint Data Loss Prevention helps organizations prevent leakage of SharePoint content, such as personally identifiable information (PII), financial data and intellectual property. It identifies sensitive information using capabilities like content scanning, keyword detection and regular expression matching, and uses the rules you define to automatically protect the data by blocking unwanted access, alerting users, encrypting the content, and so on. SharePoint DLP integrates with Microsoft 365 DLP and Azure Information Protection to provide a comprehensive approach to data protection.

3.3 Use encryption and secure transmission

Always encrypt data and use secure transmission, this will ensure that data in SharePoint is protected against unauthorized access and tampering, thereby maintaining the confidentiality and security of information assets. SharePoint uses TLS to encrypt data transmitted between clients and SharePoint servers. TLS helps establish a secure communication channel, preventing unauthorized access or interception of data during transmission.

In a hybrid SharePoint environment, SharePoint supports encryption at rest for data stored in SharePoint Online and SharePoint Server. This feature ensures that data is encrypted when it is stored on disk, adding an extra layer of protection against unauthorized access to the underlying storage. SharePoint supports secure file transfer protocols, such as Secure File Transfer Protocol (SFTP) and Secure Shell (SSH), for transferring files to and from SharePoint environments.

In SharePoint Online, data is encrypted both at rest and in transit. Microsoft uses encryption technologies to protect data stored in SharePoint Online data centers and during data transmission between clients and SharePoint Online servers.

3.4 Disable insecure transport security protocols in SharePoint Server

SharePoint Server 2013, 2016 and 2019 support Transport Layer Security (TLS) 1.2. It is highly recommended to disable previous protocols, including Secure Socket Layer (SSL) 3.0, TLS 1.0 and TLS 1.1. TLS encrypts data as it is sent between services or between the end user and services, which helps protect sensitive data in transit over the network. TLS 1.3 was released in Windows Server 2022 and is not supported in previous versions.

4. Follow access and document management best practices

The following best practices will help you achieve effective access and document management in SharePoint Server and SharePoint Online.

4.1 Identify and classify your data

Identify all the information you store in SharePoint and label it using data classification best practices. Thorough data discovery and classification will help you limit access permissions in accordance with the principle of least privilege to maintain security and regulatory compliance. It can also help you identify stale SharePoint data so you can archive or delete it.

4.2 Tag content with metadata

By adding metadata that indicate the content and value of a document or site, you make it much easier for users to find and properly handle SharePoint content. SharePoint offers some default terms for tagging content, and you can also create your own terms to meet your document management needs.

4.3 Use consistent naming conventions

Choose clear and consistent naming rules for your sites, menu options and so on, so users can immediately understand them and navigate easily instead of getting lost. For example, if two pages have the same set of sub-pages, the naming conventions should be similar.

4.4 Enable SharePoint document versioning

SharePoint document versioning enables users to track document changes and restore previous versions if required. To control storage use, you should limit how many major and minor versions are to be kept; 10 major and 10 minor versions is often a good choice.

4.5 Manage document check-in/checkout and co-authoring

SharePoint allows users to check out documents, which locks the document for editing by the user who checked it out; other users can view the document but cannot make changes. Once the user checks the document back in, it becomes available for others to edit.

SharePoint also supports co-authoring, which allows multiple users to edit a document simultaneously. SharePoint manages the locking and versioning to prevent conflicts.

4.6 Manage external sharing

External sharing gives guest users access rights to your content. SharePoint allows you to set external sharing settings at the organization level, site level and even at the individual document level. It's important to configure these settings to ensure that external data is shared securely and only with the appropriate individuals or groups.

Best practices for sharing include:

- Classify your data and determine which types of content can be shared externally.
- Block external sharing unless there is a business reason for it.
- Isolate all sites that permit external sharing into a single site collection.
- Disable anonymous sharing.
- Enable external access expiration.
- Regularly review and update sharing settings.

4.7 Establish document retention and deletion policies

Managing content commonly requires retaining content for a set period of time and deleting content permanently at the end of the retention period. You can use both retention policies and retention labels to assign retention settings to content:

- **Retention policies** — Use a retention policy to assign the same retention settings for content in a particular SharePoint site or group of sites. You can also apply a retention policy that covers content that meets specific criteria, such as containing particular keywords or types of sensitive data. Retention policy settings include Retain-only, Delete-only, and Retain and then delete.
- **Retention labels** — Retention labels can be used to assign retention settings to a folder, document or other item. Unlike retention policies, retention settings from retention labels persist with the content even if it's copied or moved to a new Microsoft 365 location. Retention labels allow you to:
 - Start the retention period either from when the content was labeled or based on an event.
 - Base the retention period on either the content creation date or the last modified date.
 - Apply retention labels to content automatically based on its type, location, metadata or other criteria.

4.8 Manage SharePoint storage

SharePoint is a key collaboration environment for users, so content can grow quickly. For on-prem installations, storage requirements can be managed as part of the broader enterprise strategy.

For SharePoint Online, you need to manage your storage in keeping with the requirements of your Microsoft 365 plan and number of licenses. Once your SharePoint storage is full, your SharePoint sites go into read-only mode, so it's vital to regularly check the storage and usage reports in the admin center. Another best practice is to monitor the Recycle Bin and empty it regularly.

Automation

Use SharePoint workflows

SharePoint workflows enable you to automate a wide range of tasks, including document review and approval, content publishing and issue tracking. SharePoint workflows can integrate with other Microsoft 365 workloads and third-party applications.

- **Plan** — Before creating a workflow, it's important to plan and design it carefully, mapping out the steps and identifying potential bottlenecks or issues. This will help ensure that the workflow is effective and efficient.
- **Customize or build** — SharePoint provides built-in approval workflows that allow users to submit content for a SharePoint site and designated personnel to approve or reject the submission. You can easily customize these

workflows to save time and reduce the risk of errors. You can also use SharePoint Designer or Power Automate to create custom workflows.

- **Test** — Before deploying a workflow, it's important to test it thoroughly to ensure that it functions as expected. This can help identify any issues or errors that need to be addressed before the workflow is put into production.
- **Secure** — Ensure that users have the appropriate permissions to initiate, participate in and approve workflows. This helps maintain security and prevent unauthorized access.

Auditing

Comprehensive auditing is critical to security in both on-prem and cloud SharePoint environments. Here are the best practices for each.

Auditing SharePoint Server

- **Keep your audit logs separately.** Unlike Usage logs, which go into a separate logging database, SharePoint audit logs are stored in the AuditData table inside the content database of the site collection. Move your audit logs out of the content databases in a secure centralized location to protect the integrity of the audit logs from intruders and malicious administrators.
- **Configure log trimming.** Audit logs can quickly expand to fill up your SQL Server. To prevent the audit log from filling the hard drive and degrading the performance of the site collection, enable audit log trimming for site collections with extensive auditing.
- **Get alerts about risky activity.** Set up alerts on changes to a SharePoint site, such as when a new document is added or modified. The alerts can be sent via email or as a notification within the SharePoint site.

To monitor activity in your on-prem SharePoint, take advantage of the various native logs and tools:

IIS logging	IIS logs all website activity to SharePoint. While not necessarily the primary data to examine for errors or performance issues, it can provide an indication of issues users are running into, including missing assets or server errors, such as HTTP 500 errors.
ULS logging	ULS is a valuable source of information about your SharePoint farm. This is the core logging mechanism of SharePoint and is often the first place a SharePoint administrator will look for any SharePoint-related errors.
Event Viewer	SharePoint stores a limited amount of information in Event Viewer, but it is very useful for service-specific and ASP.Net errors. Generally, Windows services that run SharePoint, such as the SharePoint Timer or SharePoint Administration service, will show any startups or unexpected stops in the System Event log.
Usage logging	SharePoint records a variety of information to the Usage database. This database can be directly queried either through the tables or through the built-in views.

Health Analyzer	The built-in SharePoint Health Analyzer is a set of rules that run periodically via the SharePoint Timer Service. These rules detect various issues, such as SharePoint application pools recycling, databases with a large amount of free space, and other minor or major issues with the farm.
Performance Monitor	Performance Monitor can be a useful tool for diagnosing server performance issues; you can examine outstanding ASP.NET requests, CPU usage by process and so forth.

For more robust auditing and alerting, consider using a purpose-built solution like [Netwrix Auditor for SharePoint](#).

Auditing SharePoint Online

SharePoint Online does not have a dedicated audit log search. To find SharePoint-related events, use the unified audit log. However, keep in mind that unless you have an E5 license, the log retention period is just 90 days. Moreover, even if you do store older events, audit log searches can cover only the preceding 90 days.

Therefore, to effectively monitor activity as required for security and regulatory compliance, consider [auditing SharePoint Online and other Office 365 workloads with Netwrix Auditor](#).

On-Premises SharePoint Backup and Recovery

Organizations with on-premises SharePoint deployment need to have a comprehensive backup and recovery strategy.

Back up SharePoint Server

To minimize the risk of data loss and business disruptions, ensure that your SharePoint Server data is backed up regularly.

SharePoint Server provides built-in tools that enable you to perform full farm backups, site collection backups and granular backups of specific items. However, third-party solutions offer more advanced features and flexibility, such as backup scheduling. In either case, be sure to:

- **Regularly test your backups** to ensure that they are functioning correctly and that you can restore data when needed. This helps to verify the integrity of your backup process.
- **Store your backups in a secure location** separate from your production environment, either on premises or in the cloud.

- **Choose a backup schedule** that aligns with your organization's recovery point objectives (RPO) and recovery time objectives (RTO).

Use the Recycle Bins for limited recovery

SharePoint offers recycle bins to help users and administrators restore recently deleted items, such as documents, libraries, lists, folders and even sites. There are two types of Recycle Bin:

- **Site Recycle Bin** — When items are deleted from a site, they are held in the site's Recycle Bin until they are manually deleted or the purge period expires.
- **Site collection Recycle Bin** — This bin stores all items deleted from any site in the site collection. This includes items deleted from the site Recycle Bins before the purge period ends, which helps site collection administrators protect information from inappropriate deletion.

Have a robust recovery plan

However, the recycle bins cannot handle all granular restore scenarios, and they do not enable full disaster recovery. A solid recovery plan must include the following:

- Assess how much data has been lost or corrupted. This could range from recovering a single document or list item to restoring an entire site collection or farm.
- After restoring data, test that the operation was successful and the data is accessible to users as intended.
- If the data loss has impacted users or business processes, it's important to communicate with all stakeholders about the recovery efforts and how they may be affected.
- After a recovery, it's valuable to review the incident to identify the root cause of the data loss or corruption so you can take steps to prevent similar incidents in the future.

On-Premises SharePoint Setup Best Practices

Creating an on-prem SharePoint installation can be a complex process, so consider engaging IT professionals with expertise in SharePoint implementation.

Understand your requirements and constraints

When planning your SharePoint Server environment, be sure to determine (and document!) the following:

- Budget
- Hardware and other investments that can be reassigned to support the new initiative
- High availability (HA) requirements & Granular restore and disaster recovery (DR) requirements

- Anticipated content size
- Anticipated total number of users
- Anticipated number of concurrent users
- Services required

Choose your topology with care

Here are the most common SharePoint Server topology strategies:

- **Single-server farm** — This option consists of a single server that runs both SharePoint Server and SQL Server. It is possible to add additional SharePoint servers later.
- **Three-tier farm** — One of the most common farm types, the three-tier farm consists of one web front end, one application server and one SQL Server. The web front end is simply a SharePoint Server that handles user traffic, while the application server is a SharePoint Server that handles most SharePoint services, such as Business Data Connectivity Services and the Managed Metadata Service.
- **Traditional highly available farms** — These farms can suffer the loss of one or more SharePoint servers and SQL servers while still serving users. An example would be two web front ends, two application servers, and two SQL servers using a form of high availability like SQL clustering or database mirroring.
- **MinRole farm** — Servers are deployed with predefined roles (Distributed Cache, Front End, Application or Search), and the appropriate services are automatically provisioned. If services are started that do not comply with a server's MinRole, that server will be considered out of compliance. For a high-availability MinRole farm, you need two SharePoint servers with each of the four roles.

Consider geographical constraints

To avoid object synchronization issues, farms must have a 99% 1 ms round-trip time on average over 10 minutes. Farms also must have 1 Gbps connectivity between all farm members and SQL servers that are serving the farm in a read-write capacity or are in a synchronous form of replication with the read-write SQL Server. In practice, this means that each farm member or SQL Server in synchronous replica mode must be within a radius of approximately 186 miles (300 km).

Plan for SQL Server availability

To keep the SQL Server databases that support your on-prem SharePoint sites available, choose one of the following options:

- **Database mirroring** — Database mirroring involves adding a High-Performance mode node to your SQL Server configuration. This node can coexist with High Safety, with or without automation failover in place. Failover in High Performance mode is a manual process; databases will not be brought online automatically.

- **Log shipping** — Log shipping is the transfer of transaction log backups from one SQL Server to another. The destination SQL Server then restores the transaction log backups to the target database. This method allows you to keep the databases up to date with additional replication options available outside of SQL Server.
- **AlwaysOn availability groups** — Adding an asynchronous remote SQL Server to your availability group allows you to have a single SQL Server in a disaster recovery location. The remote SQL Server must be set to asynchronous mode, which has a manual failover process: As soon as the link between production has been severed, the databases will enter a read-write state that allows the disaster recovery farm to be brought online.

Control permissions inheritance

By default, child objects inherit permissions from their parent objects. For example, documents within a site inherit the permissions assigned to the site. However, administrators can break inheritance and customize permissions for specific objects.

It is important to carefully manage permission inheritance in SharePoint to ensure that users have the appropriate level of access to the content they need, while also maintaining security and preventing unauthorized access.

Implement a regular SharePoint Server patching process

Keeping all SharePoint Server machines up to date on patches is vital to protect against known exploits. To upgrade a farm without taking it offline, you need to use “highly available upgrades” option, which takes only one server in the farm offline at a time.

Conclusion

Following these configuration and security best practices will help you keep your Microsoft SharePoint environment highly available and secure, driving adoption and enabling you to make the most of your investment in the collaboration platform.



Data security that starts with identity™

Netwrix Auditor for SharePoint and Teams

- Tracks who read, modified or deleted which content
- Reveals effective user permissions
- Identifies items with broken inheritance
- Provides details about each change to configurations, permissions or content
- Highlights potential security risks, such as documents that have been shared with external users or that can be accessed by everyone in the organization

[Start online demo](#)

Why Netwrix?

Enhanced data security

Integrates easily with Netwrix Auditor to reveal who has access to sensitive data, monitor how they are using that access, and alert on suspicious activity around the data.

Reusable and incremental Indexing

Eliminates the need for lengthy data re-collection every time a new file appears, or a classification rule is changed.

Non-intrusive architecture

Operates in agentless mode and does not interfere with your file system when updating content metadata. Instead, all index and classification information is collected, analyzed, stored and updated on a separate server.

Next Steps

Start free trial
netwrix.com/auditor

Request pricing
netwrix.com/buy

Contact us
netwrix.com/contact

Corporate Headquarters: 6160 Warren Parkway Suite 100, Frisco, TX, US 75034

Phone: 1-949-407-5125

Toll-free: 888-638-9749

EMEA: +44 (0) 203-588-3023